

****Deliberation SAN-2023-008 of June 8, 2023****

****National Commission for Information Technology and Liberties****

****Nature of the deliberation: Sanction****

****Legal status: In force****

****Date of publication on Légifrance: Thursday, June 15, 2023****

****Deliberation of the restricted formation no SAN-2023-008 of June 8, 2023 concerning the company KG COM****

The National Commission for Information Technology and Liberties, convened in its restricted formation composed of Mr. Alexandre LINDEN, president, Mr. Philippe-Pierre CABOURDIN, vice-president, Mr. Alain DRU, Mr. Bertrand du MARAIS, and Ms. Christine MAUGÜÉ, members;

****Considering**** the regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of personal data and on the free movement of such data ("GDPR");

****Considering**** law no. 78-17 of January 6, 1978, relating to information technology, files, and liberties, particularly its articles 20 and following;

****Considering**** decree no. 2019-536 of May 29, 2019, taken for the application of law no. 78-17 of January 6, 1978, relating to information technology, files, and liberties;

****Considering**** deliberation no. 2013-175 of July 4, 2013, adopting the internal regulations of the National Commission for Information Technology and Liberties;

****Considering**** decision no. 2020-267C of October 20, 2020, of the president of the National Commission for Information Technology and Liberties, assigning the secretary general to carry out or have carried out a verification mission of the processing operations implemented by the company KG COM or on its behalf;

****Considering**** the decision of the president of the National Commission for Information Technology and Liberties designating a rapporteur before the restricted formation, dated December 23, 2021;

****Considering**** the report of Ms. Sophie LAMBREMON, reporting commissioner, notified to the company KG COM on July 7, 2022;

****Considering**** the written observations submitted by the company KG COM on August 8, 2022;

****Considering**** the other documents in the file;

****Present**** at the meeting of the restricted formation on September 15, 2022:

- Ms. Sophie LAMBREMON, commissioner, heard in her report;

****As representatives of the company KG COM:****

- [...]

The company KG COM having spoken last;

The restricted formation adopted the following decision:

****I. Facts and Procedure****

1. The company KG COM (hereinafter "KG COM" or "the company") is a simplified joint-stock company, registered in the Lyon Trade and Companies Register under number 538 563 917, with its registered office located at 40 rue de Bruxelles, in Villeurbanne (69100). The company operates several websites to offer its clients fortune-telling consultations via chat or telephone, including the website <http://www.voyance-en-direct.tv/>. The company employs six employees.

2. In 2019, the net revenue of the company amounted to [...] euros and its net profit was [...] euros. In 2020, its net revenue amounted to [...] euros with a net loss of [...] euros.

3. On October 1, 2020, a news article published on the website of the media Numerama revealed the existence of a personal data breach concerning the data stored on KG COM's server. According to this article, the company's database, which was not subject to specific security measures, was freely accessible on the Internet until July 23, 2020. Numerous data, including identification and contact data, were thus exposed.

4. On January 21, 2021, a control delegation from the National Commission for Information Technology and Liberties (hereinafter "CNIL" or "Commission") conducted a document-based inspection by sending a questionnaire to the company, to which the latter responded by a letter

received on March 25, 2021.

5. An online inspection was also conducted on April 15, 2021, on the website www.voyance-en-direct.tv, published by the company. The report no. 2020-267/1, drawn up at the end of the inspection, was notified to the organization on April 26, 2021. The company provided the delegation with...

compliance with legal obligations. The report indicates that this practice may lead to the retention of personal data that is not necessary for the purposes for which it is processed, thus potentially violating the principle of data minimization as established in Article 5-1-c of the GDPR.

20. The rapporteur emphasizes that the company must ensure that the data collected is adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed. The systematic recording of all calls may not meet this requirement, as it could include personal data that is not essential for the stated purposes.

21. Furthermore, the rapporteur notes that the company has not provided sufficient justification for the necessity of retaining all recorded calls, particularly when it comes to calls that do not result in a contract or do not involve any significant interaction that would warrant such retention.

22. In light of these observations, the rapporteur concludes that the company has failed to comply with its obligations under Article 5-1-c of the GDPR regarding the adequacy, relevance, and non-excessiveness of the personal data processed.

B. On the breach related to the obligation to ensure the accuracy of personal data in accordance with Article 5-1-d of the GDPR

23. Article 5, paragraph 1, d) of the GDPR states that personal data must be accurate and, where necessary, kept up to date. The company is responsible for taking every reasonable step to ensure that personal data that is inaccurate, having regard to the purposes for which it is processed, is erased or rectified without delay.

24. The rapporteur observes that the company has not implemented adequate measures to ensure the accuracy of the personal data it processes. This includes a lack of regular reviews or updates to the data held, which may lead to inaccuracies that could affect the rights of individuals.

25. The rapporteur highlights that the company must establish processes to verify the accuracy of the data it collects and to ensure that any inaccuracies are corrected promptly. Failure to do so constitutes a breach of Article 5-1-d of the GDPR.

C. On the breach related to the obligation to comply with the principles of accountability and transparency in accordance with Articles 5-2 and 12 of the GDPR

26. Article 5, paragraph 2, of the GDPR establishes the principle of accountability, which requires that the data controller be able to demonstrate compliance with the principles relating to the processing of personal data. Article 12 emphasizes the need for transparency in the processing of personal data, ensuring that individuals are informed about how their data is being used.

27. The rapporteur notes that the company has not adequately documented its data processing activities or provided clear and accessible information to individuals regarding the processing of their personal data. This lack of documentation and transparency undermines the accountability principle and may prevent individuals from exercising their rights under the GDPR.

28. The rapporteur concludes that the company has failed to meet its obligations under Articles 5-2 and 12 of the GDPR, which requires both accountability and transparency in the processing of personal data.

D. On the proposed administrative fine

29. In light of the identified breaches, the rapporteur recommends that an administrative fine be imposed on the company. The fine should be proportionate to the severity of the violations and take into account the company's cooperation during the investigation, as well as any mitigating factors that

may apply.

30. The rapporteur suggests that the decision to impose the fine should be made public, with the caveat that the company should not be identifiable by name after a period of two years from the date of publication, in order to balance the need for transparency with the protection of the company's reputation.

31. The rapporteur emphasizes that the imposition of the fine serves not only as a punitive measure but also as a deterrent to ensure that the company and other organizations take their obligations under the GDPR seriously and implement necessary measures to protect personal data.

****Judicial requisition perspective.**** The rapporteur considers that this leads to the collection of data that is not limited to what is necessary in light of the pursued purposes.

20. In defense, the company indicates that it has ceased offering its clients telephone psychic consultations.

21. To justify past actions, it states that these recordings allowed it to monitor the statements made by the psychics during consultations, particularly to assess their competencies. According to it, recording a sample of the consultations would not meet its needs.

22. The restricted panel notes the cessation of telephone psychic consultations, which implies the cessation of recordings of the telephone calls made between teleoperators and prospects, as well as those made between psychics and clients.

23. However, the restricted panel observes that on the day of the inspections, the company systematically and fully recorded these telephone calls for the purposes of quality control, proof of contract subscription, and in anticipation of judicial requisitions.

24. The restricted panel notes that the company does not provide justification, for the past, regarding the necessity of systematically recording all telephone conversations, on the one hand, between teleoperators and prospects, and on the other hand, between psychics and clients, for the purposes of quality control, proof of contract subscription, and in anticipation of judicial requisitions.

25. However, a data controller cannot implement a processing of personal data without ensuring that it is necessary for its needs, especially when it relies on a particularly intrusive system for employees.

26. Regarding the full and systematic recording of telephone calls for the purpose of quality control, the restricted panel considers that the purpose of monitoring the quality of service provided by teleoperators and psychics can be achieved by a less intrusive means.

27. In this regard, it notes that the implementation of occasional and random recording of only a few telephone conversations allows the person responsible for quality control to have the necessary elements for evaluating the quality of the services offered by the company.

28. Since quality control can be carried out by sampling, the restricted panel considers that the establishment of a systematic recording system for telephone calls made, on the one hand, between teleoperators and prospects, and on the other hand, between psychics and clients, is excessive in light of the pursued purpose.

29. The restricted panel recalls that it has already considered, in its deliberation No. SAN-2020-003 of July 28, 2020, regarding a company that recorded telephone conversations received by customer service employees for training purposes, that "the company does not justify the necessity of recording all telephone conversations made by the customer service, in light of the purpose of the processing, namely the training of employees. (...) While the number of recordings may vary depending on each employee and the circumstances, particularly the training needs of that employee, (...) the company does not demonstrate having implemented, for the past and the future, a recording of employees' telephone conversations limited to what is necessary in light of the pursued purpose. However, a data controller cannot implement a processing of personal data without ensuring that it is necessary for its needs, especially when it relies on a particularly intrusive system for employees. The restricted panel therefore considers, at

Given these elements, a breach of Article 5-1-c) of the GDPR is established. 30. Regarding the full and systematic recording of telephone calls for the purpose of proving the subscription of the contract, the restricted panel notes that, in this case, prospects provide their phone numbers to the company via one of the websites it operates in order to obtain information about the clairvoyance services offered.

Following this request for information, the company's tele-advisors call the prospects to provide this information and, if applicable, schedule an appointment with a clairvoyant. 31. The restricted panel considers that a data controller wishing to record telephone conversations for evidentiary purposes must demonstrate that they do not have other, less intrusive means to prove that the distance contract was indeed concluded with the concerned person. 32. The restricted panel considers that, in this case, the existence of the distance contract can be proven by another, less intrusive means. 33. Indeed, Article L.221-16 of the Consumer Code provides that when a professional contacts a consumer by telephone with a view to concluding a contract for the sale of goods or the provision of services, the consumer is only bound by this offer after having signed and accepted it on a durable medium. 34. The restricted panel therefore considers that, since proof of the subscription of a distance contract, following a telephone solicitation, can be provided by the written confirmation of the offer, the recording of telephone conversations between tele-operators and prospects for the purpose of proving the formation of the contract does not appear necessary. 35. Furthermore, the restricted panel notes that no contract is concluded during the telephone calls between the clairvoyants and the clients, so that the recording of these conversations is not justified for the purpose of proving the subscription of a contract. 36. Regarding the full and systematic recording of telephone calls in anticipation of judicial requisitions, the restricted panel notes that while it is necessary for data controllers to comply with judicial requisitions they receive concerning the data they process for their own needs, they are not required to organize, in advance, the collection of personal data in anticipation of a potential judicial requisition. 37. Therefore, the restricted panel considers that the recording of telephone calls made, on the one hand, between tele-operators and prospects, and on the other hand, between clairvoyants and clients, in order to respond to judicial requisitions, is not justified. 38. The restricted panel therefore considers, in light of these elements, that a breach of Article 5, paragraph 1, c) of the GDPR is established. It notes that the company has ceased to offer its clients consultations by telephone, which implies the cessation of telephone recordings at least between clairvoyants and clients, but this cannot exempt the company from its liability for the past. 39. Secondly, the rapporteur notes that during the telephone calls between tele-operators and clients, the latter are invited to provide their banking details. She considers that the audio recording of the part of the conversation related to the collection of clients' banking data cannot be justified for the purposes of quality assurance or for evidentiary purposes. 40. In defense, the company justifies, for the past, the collection of its clients' banking data by the reservation of appointments with a clairvoyant, the simplification of payment for subsequent consultations, the payment of subscriptions, and the fight against fraud. 41. It years.50. The restricted formation notes that the company has not defined a specific retention period for personal data that aligns with the purpose of the processing, which is to manage the commercial relationship and customer follow-up.51. Consequently, it concludes that a violation of Article 5(1)(e) of the GDPR has occurred, as the company retains personal data beyond the necessary duration for the purposes for which they are processed.

C. On the violation related to the obligation to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, in accordance with Article 32 of the GDPR⁵². According to Article 32 of the GDPR, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, as appropriate, the pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing.⁵³ The restricted formation observes that the company did not implement any specific measures to ensure the security of the personal data collected, particularly the banking data of clients, which is sensitive information.⁵⁴ It notes that the company did not conduct any risk assessments or implement any encryption measures for the banking data collected during the telephone calls.⁵⁵ Therefore, it concludes that a violation of Article 32 of the GDPR has been established, as the company failed to take appropriate measures to ensure the security of personal data.

D. On the violation related to the obligation to inform data subjects of their rights, in accordance with Articles 13 and 14 of the GDPR⁵⁶. Under Articles 13 and 14 of the GDPR, the data controller must provide data subjects with information regarding the processing of their personal data, including the purposes of the processing, the legal basis for the processing, the recipients of the data, and the rights of the data subjects.⁵⁷ The restricted formation finds that the company did not adequately inform clients about their rights regarding their personal data, particularly concerning the processing of their banking data.⁵⁸ It concludes that a violation of Articles 13 and 14 of the GDPR has occurred, as the company failed to fulfill its obligation to inform data subjects about their rights.

E. Conclusion⁵⁹. In light of the above findings, the restricted formation concludes that the company has committed multiple violations of the GDPR, specifically Articles 5(1)(c), 5(1)(e), 32, and 13 and 14.⁶⁰ The restricted formation recommends that the company take immediate corrective actions to address these violations and ensure compliance with the GDPR moving forward. the respect of the applicable legal provisions." 62. The restricted formation emphasizes that the company must ensure that the retention of personal data is limited to what is necessary for the purposes for which they are processed. 63. It concludes that the company must implement measures to ensure compliance with these principles, including the establishment of a clear data retention policy that specifies the duration of data retention based on the purpose of processing. 64. The restricted formation also recommends that the company regularly review its data retention practices and purge unnecessary data to minimize risks associated with data breaches and ensure the protection of clients' personal information. the limitation period applicable. It will be necessary to provide for a dedicated archive database or a logical separation in the active database, after sorting the relevant data to be archived. (...) "62. Consequently, the restricted panel considers that these facts constitute a breach of the provisions of Article 5, paragraph 1, e) of the GDPR. C. On the breach relating to the obligation to process data lawfully in accordance with Article 6 of the GDPR. 63. According to Article 6 of the GDPR, "processing shall be lawful only if and to the extent that at least one of the following applies: a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes; b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract; c) processing is necessary for compliance with a legal obligation to which the controller is subject; d) processing is necessary in order to protect the vital interests of the data subject or of another natural person; e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller; f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child." 64. The rapporteur notes that in the context of chat consultations, the company retains its clients' banking data beyond the strictly necessary time for the completion of the transaction, to facilitate subsequent payments, and this, without obtaining their prior consent, for example on the data collection form. 65. In defense, the company argues that the retention of its clients' banking data is for the purpose of purchasing credits and is based on the contract that binds it to its clients. It also considers that the retention of this data for the purposes of combating fraud is based on its legitimate interest. 66. The restricted panel recalls that the legal basis for processing banking data may vary, in particular depending on the purpose pursued. 67. In this case, firstly, regarding the purpose related to combating fraud, the restricted panel considers that the legal basis for the retention of banking data is, in accordance with what the company argues, its legitimate interest, which is not contested by the rapporteur. 68. In this regard, the Commission indicates, in its deliberation No. 2018-303 of September 6, 2018, adopting a recommendation concerning the processing of payment card data in the context of the sale of goods or the provision of services at a distance, that "the retention of payment card data beyond the completion of a transaction for the purposes of combating payment card fraud does not fall within the scope of the contract. It indeed considers that this processing falls under the legitimate interest of the data controller, provided that the interests or rights and freedoms of the individuals are not disregarded in

accordance with Article 6-1-f of the GDPR, particularly by ensuring compliance with the principles of transparency and the effectiveness of the exercise of their rights by the data subjects." 69. Secondly, regarding the purpose related to re-crediting, the restricted panel considers that clients' banking data is retained to offer an additional service to clients, namely not having to re-enter their card number when purchasing additional credit, which goes beyond execution of the concluded contract. 70. Consequently, it considers that the processing of clients' banking data for this purpose cannot rely on the contract concluded between the client and the company and requires the prior consent of the clients to be obtained. 71. The restricted formation recalls, by way of illustration, that the Commission estimates, in its aforementioned deliberation, that for the purposes of a one-time payment, "the credit card number can only be collected and processed to enable the execution of a transaction within the framework of the execution of the contract concluded by the data subject in accordance with Article 6-1-b of the GDPR (contractual execution). Thus, in the case of a contract involving a one-time payment, the Commission believes that the data should not be retained beyond the time of the commercial transaction." 72. Also by way of illustration, in the aforementioned deliberation, the Commission indicates that "the retention of the client's card number in order to facilitate any subsequent payments, and potentially to allow for a 'one-click' purchase on the merchant's site, goes beyond the execution of the concluded contract. It holds that this option constitutes an independent choice from the initial act that led to the collection of banking details and recalls that such processing requires the prior collection of the free, specific, informed, and unambiguous consent of the individuals, in accordance with Article 6-1-a of the GDPR." 73. The restricted formation also recalls that in its decision of December 10, 2020, No. 429571, the Council of State held that "the CNIL was right to consider that, in general, the retention of the credit card numbers of clients of online shopping sites to facilitate subsequent purchases should be subject to the explicit consent of the data subject. It follows that the argument based on the non-compliance by the disputed deliberation with the regulation of April 27, 2016 must be dismissed." 74. Consequently, the restricted formation considers that a breach of Article 6, paragraph 1, of the GDPR is constituted, as the company retains its clients' banking data beyond the execution of the transaction, in order to facilitate the purchase of additional credit, without obtaining their prior consent. D. On the breach relating to the obligation to obtain prior consent for the collection of special categories of data in accordance with Article 9 of the GDPR. 75. Under Article 9 of the GDPR, the processing of personal data revealing information concerning the health or sexual orientation of a natural person is prohibited unless it falls under one of the conditions set out in Article 9-2-a) to j) of the GDPR. 76. The rapporteur notes that the psychics have the possibility to write comments on the company's client files after a consultation. She notes that among these comments are information disclosed by clients regarding their health and sexual orientation. She observes that, at the time of creating the user account, the company does not obtain the agreement of the data subject regarding the use of this data. 77. In defense, the company argues that the mere fact of a person addressing a psychic and spontaneously communicating sensitive data during the exchange constitutes a clear positive act of transmitting certain data and thus consent. 78. Furthermore, the company asserts that the comments from the psychics do not, for the most part, allow for the identification of the data subject, as the data is pseudonymized. 79. The restricted formation notes, first of all, that during consultations, clients may communicate to the psychics data relating to their health status and sexual orientation. At the end of the consultations, the psychics make comments on their clients' files. These files are retained in their business tool. restricted formation notes that, in the context of their comments, the observers mention information relating to the health status and sexual orientation of clients that they collected during the consultation. 80. The restricted formation considers that the measures taken by the company do not correspond to an anonymization of client data but rather to a simple pseudonymization, insofar as the identifier associated with the comment and the information it contains allow for the re-identification of the concerned client. 81. The restricted formation further notes that, in the absence of other conditions that could be invoked in the specific case under Article 9-2-b) to j) of the GDPR, such processing can only be implemented based on the explicit consent of the data subject for the processing of their personal data for one or more specific purposes, in accordance with Article 9-2-a) of the GDPR. The restricted formation recalls that the explicit nature of consent is assessed on a case-by-case basis and depends

on the context of the processing of sensitive data. When the service requested by the user necessarily involves the processing of sensitive data, it is, however, essential that the user is fully aware that their sensitive data will be processed and sometimes retained by the data controller, which generally implies explicit information on this point at the time of obtaining consent. 82. The restricted formation recalls that according to Article 4, paragraph 11, of the GDPR, the notion of consent is understood as any manifestation of will, free, specific, informed, and unambiguous by which the data subject accepts, by a declaration or by a clear affirmative action, that personal data concerning them be subject to processing. 83. On the one hand, the restricted formation considers that the explicit nature of the consent provided for in Article 9, paragraph 2, a) of the GDPR implies allowing the data subject to express, through a positive action, their agreement to the processing of sensitive data, demonstrating the materiality of their consent. 84. For clarification, the restricted formation recalls that in its guidelines on consent under Regulation 2016/679 of April 10, 2018, the European Data Protection Board (hereinafter "EDPB") states that "the GDPR stipulates that a 'declaration or a clear affirmative action' is a sine qua non condition for 'standard' consent." Given that the requirements for 'standard' consent in the GDPR are already set at a higher level than those of Directive 95/46/EC, it is appropriate to specify what additional efforts a data controller should undertake to obtain the explicit consent of a data subject in accordance with the GDPR. The term explicit relates to how consent is expressed by the data subject. It implies that the data subject must make an express consent declaration. An obvious way to ensure that consent is explicit would be to confirm consent expressly in a written declaration. Where appropriate, the data controller could ensure that the written declaration is signed by the data subject to prevent any potential doubt and any potential lack of evidence in the future. However, such a signed declaration is not the only way to obtain explicit consent [...] (guidelines 2016/679 WP259 rev.01 of April 10, 2018, page 21). 85. The restricted formation emphasizes that it has, on several occasions, adopted corrective measures against data controllers who do not obtain the explicit consent of individuals to collect and process their "sensitive" data, notably in its deliberations No. 2016-405 of December 15, 2016, and No. 2016-406 of December 15, 2016, as well as in its deliberation No. SAN-2017-006 of April 27, 2017, in which it considered that "the spontaneous provision of such data does not exempt the company from the obligation to obtain the express consent of the individuals who must be able to manifest their agreement to the processing of sensitive data through a positive action, thereby confirming that consent is given with full knowledge of the facts." 86. The restricted panel therefore notes that the mere desire to receive a fortune-telling service and the act of voluntarily providing sensitive information do not constitute explicit consent from the individuals concerned. 87. It considers that the company should have provided individuals from whom it collects particular categories of data with a means to ensure that they consent explicitly through a clear positive act. 88. Furthermore, the consent obtained under Article 9, paragraph 2, a) of the GDPR must be interpreted in light of the definition set out in Article 4, paragraph 11, of the GDPR, which implies that, in this case, for valid consent, the individual concerned must, beforehand, be fully informed about the particular nature of the data they communicate, notably in that such data may reveal their health status and sexual orientation, as well as the use that will be made of this data. 89. The restricted panel notes that the company does not provide specific information to the individuals concerned regarding the collection and processing of their health data and information related to their sexual orientation. 90. It considers that the company should have provided the individuals concerned with specific information, for example, at the time of creating their user account. 91. Consequently, the restricted panel considers that the company does not obtain the explicit consent of the individuals concerned, so it cannot invoke the exception to the prohibition on collecting and processing particular categories of data, as provided for in Article 9, paragraph 2, a), of the GDPR. 92. As a result, the restricted panel considers that in the absence of obtaining the prior and explicit consent of clients for the collection of their health data and information related to their sexual orientation, a breach of Article 9 of the GDPR is constituted. E. On the breach relating to the obligation of transparency under Article 12 of the GDPR 93. Article 12, paragraph 1, of the GDPR states that "the data controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 and Article 34 regarding the processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language,

particularly when providing information specifically addressed to a child. The information shall be provided in writing or by other means, including, where appropriate, by electronic means." 94. The rapporteur criticizes the company for not providing the individuals concerned with the information referred to in Article 13 of the GDPR in a sufficiently accessible manner at the time of collecting personal data for the purpose of creating a user account. 95. In defense, the company argues that no legal provision prescribes the practical modalities that the data controller must respect to inform its users about the processing of personal data. It also indicates that the separation of its privacy policy and the "general terms and conditions of sale" is underway. 96. The restricted panel recalls that information is easily accessible, within the meaning of Article 12 of the GDPR, if it is provided to the user without the user needing to actively seek it out. 97. On the one hand, the of the checks regarding the recording of telephone conversations, the possibility to oppose it, and the processing of data collected during those calls.

111. Consequently, the restricted formation concludes that a breach of Article 13 of the GDPR has occurred, considering, on one hand, the incompleteness of the information provided to users, as long as the company has not amended the information notice on its website, and on the other hand, the lack of information provided to prospects at the time of the checks regarding the recording of telephone conversations, the possibility to oppose it, and the processing of data collected during those calls.

112. The restricted formation also notes that the company has not demonstrated that it has taken adequate measures to ensure compliance with the obligations set out in Article 13 of the GDPR, particularly regarding the provision of comprehensive and easily accessible information to users and prospects.

113. In light of the above, the restricted formation recommends that the company take immediate action to rectify these deficiencies and ensure compliance with the GDPR, particularly by updating its privacy policy and ensuring that all necessary information is clearly communicated to users and prospects in a timely manner.

114. The restricted formation emphasizes the importance of transparency in data processing activities and the need for companies to uphold their obligations under the GDPR to protect the rights of individuals.

115. Finally, the restricted formation calls upon the company to implement training and awareness programs for its staff to ensure that all employees understand the importance of data protection and the requirements of the GDPR.

G. On the breach relating to the obligation to frame the relationship between the data controller and the processor in accordance with Article 28 of the GDPR.

111. Article 28, paragraph 3, of the GDPR provides that the processing carried out by a processor on behalf of a data controller is governed by a contract that defines the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data, the categories of data subjects, as well as the obligations and rights of the data controller. This contract also stipulates the conditions under which the processor commits to carry out processing operations on behalf of the data controller.

112. The rapporteur notes that among the contracts and annexes of subcontracting provided by the company, two are not signed by the service providers and others do not contain all the mandatory mentions.

113. In defense, the company does not contest the absence of signatures by its service providers on two of the subcontracting contracts, nor the absence of certain mandatory mentions that should appear in the provided subcontracting contracts. However, it requests the restricted panel to note the existence of these agreements, implying its willingness to comply with Article 28 of the GDPR.

114. The restricted panel first notes that the annex of the outsourcing contract, which binds the company to the processor for which it attributes responsibility for the security incident, does not contain all the information required by Article 28, paragraph 3, of the GDPR and is not signed by the provider.

115. Next, it notes that the contract concluded between the company KG COM and the provider in charge of telephony does not contain a subcontracting clause, in the sense of Article 28, paragraph 3, of the GDPR.

116. Finally, it notes that the annexes to the contracts concluded between the company KG COM and the affiliate partners contain a subcontracting clause that is not compliant with Article 28, paragraph 3, of the GDPR, as it does not include all the mandatory mentions, particularly the obligation for the processor to process personal data only on documented instructions from the data controller. It also notes that one of these annexes is not signed by the affiliate partner.

117. The restricted panel considers that these facts do not allow for effective protection of personal data processed through contractual guarantees.

118. Consequently, the restricted panel considers that these facts constitute a breach of Article 28, paragraph 3, of the GDPR, which the company does not contest.

H. On the breach relating to the obligation to ensure data security in accordance with Article 32 of the GDPR.

119. According to Article 32 of the GDPR, "1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among other things, as necessary: a) the pseudonymization and encryption of personal data; b) the means to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services; [...]".

120. First, the rapporteur notes that, when creating a user account on the website www.voyance-en-direct.tv, individuals can choose a password consisting of a single character. Furthermore, access to the company's CRM tool is done using an identifier and a password created either by the president of the company and the the concerned employee, without specific rules regarding the complexity of passwords, nor automatic modification of the password upon first login, either by the administrator using a generator that provides a password composed of nine to twelve characters, including alphanumeric and special characters.

121. In defense, the company does not provide any elements in response to the lack of robustness of the passwords.

122. The restricted formation recalls that under Article 32 of the GDPR, to ensure the protection of personal data, it is the responsibility of the data controller to take "appropriate technical and organizational measures to ensure a level of security appropriate to the risk."

123. The restricted formation considers that overly permissive password complexity rules, which allow the use of insufficiently robust passwords, can lead to attacks by unauthorized third parties, such as "brute force" or "dictionary" attacks, which consist of systematically and successively testing numerous passwords and thus lead to the compromise of associated accounts and the personal data they contain.

124. It notes, in this regard, that the necessity of a strong password is recommended both by the National Cybersecurity Agency of France (ANSSI) and by the Commission in its deliberation No. 2017-012 of January 19, 2017, a requirement confirmed in its deliberation No. 2022-100 of July 21, 2022.

125. The restricted formation emphasizes that it has, on several occasions, adopted financial sanctions where the characterization of a breach of Article 32 of the GDPR is the result of insufficient measures to ensure the security of processed data. Deliberations No. SAN-2019-006 of June 13, 2019, No. SAN-2019-007 of July 18, 2019, and No. SAN-2022-018 of September 8, 2022 specifically address the insufficient robustness of passwords.

126. In this case, the restricted formation notes that the passwords of users of the website www.voyance-en-direct.tv can be composed of a single character.

127. It considers that the risk faced by the concerned individuals is real: a third party who has accessed the password could access the personal data present in the account of the concerned individual, consult the history of their credit consumption, and/or change the password of their account, without the user's knowledge.

128. Furthermore, the restricted formation notes the lack of robustness of the passwords allowing the company's employees to access its CRM tool, given the absence of complexity rules when they are created by the company's president and the concerned employee, and the absence of additional security measures when they are created by the administrator (passwords composed of nine to twelve alphanumeric and special characters).

129. The restricted formation also considers that the password creation procedure does not ensure the confidentiality of the data since when the password is created by the administrator, they transmit it to the company's president so that he can communicate it to the concerned employee, and when it is not created by the administrator, the company's president creates it in conjunction with the concerned employee.

130. These facts constitute a real risk for the concerned individuals: an unauthorized third party who has accessed the password could access a large number of personal data, including sensitive data.

131. Therefore, taking into account these risks for the protection of personal data and the privacy of individuals leads the restricted formation to consider that the measures deployed to ensure data security in this case are insufficient.

132. In these circumstances, given the risks faced by the individuals mentioned above, as well as the sensitivity of certain data (health data, data related to sexual orientation, banking data), the restricted formation considers that the organization has failed to meet the obligations incumbent upon it under Article 32 of the GDPR.

133. Secondly, the rapporteur notes that the mechanism used by the company to encrypt banking data presents vulnerabilities (pre-determined initialization vector, reuse of it, and obsolescence of the library used), which does not allow, given the sensitivity of this data, to guarantee a level of security appropriate to the risk.

134. In defense, the company argues that its subcontractor, the company [...], should have advised it on the encryption of data.

135. The restricted formation recalls that the protection of banking data requires the implementation of enhanced security measures given their highly personal nature, such as encryption.

136. In this case, the restricted formation notes that it appears from the case files that the company [...] was not responsible for the encryption of the banking data of the clients of the company KG COM but for the management and hosting of the data.

137. The restricted formation also notes that it appears from the case files that the company KG COM itself carried out the encryption of its clients' banking data, and this in an unsecured manner.

138. Indeed, the restricted formation observes that the CWE (Common Weakness Enumeration) list from MITRE (a U.S. non-profit organization involved in system engineering and information technology), which enumerates software weaknesses, identifies as vulnerabilities the generation of a predictable initialization vector with the CBC mode, as in this case, and the reuse of an initialization vector. The restricted formation notes that

when the initialization vector is not random but determined, the plaintext message is always encrypted in the same way. It is therefore possible to compare several encrypted messages and identify the plaintext messages to which they correspond. Furthermore, by reusing the initialization vector, it becomes common to all the data encrypted with the unique key.¹³⁹ The restricted formation also

notes that Mcrypt, the cryptographic library used by the company, has been considered obsolete and was removed in 2017, so the use of this functionality is discouraged in the PHP documentation.¹⁴⁰ Consequently, the restricted formation considers that the aforementioned facts constitute a breach of Article 32 of the GDPR, as the mechanism implemented by the company KG COM to encrypt its clients' banking data does not ensure an appropriate level of security relative to the risk.¹⁴¹ Thirdly, the rapporteur notes that during inspections, access to the website www.voyance-en-direct.tv was carried out using the "HTTP" protocol, including the page related to the collection of banking data. However, this protocol is not a secure protocol, which means that the site is vulnerable to attacks and allows the plaintext reading of streams containing personal data, including banking data, between the user's browser and the server hosting the site.¹⁴² In defense, the company states that it has modified its "HTTP" protocol to TLS on the website www.voyance-en-direct.tv, following the notification of the report.¹⁴³ The restricted formation recalls that, pursuant to Article 32 of the GDPR, it is the responsibility of the data controller to take "appropriate technical and organizational measures to ensure a level of security appropriate to the risk."¹⁴⁴ The restricted formation notes that the "HTTP" protocol is a communication protocol that does not allow for either the authentication of the website or the encryption of data during its transmission to the servers hosting the company's website, which does not guarantee the authenticity of the site being consulted, nor the integrity and confidentiality of the exchanged data, exposing the personal data processed through these pages to risks of eavesdropping, interception, or modification without the user's knowledge, which can lead to violations of the privacy of the individuals concerned.¹⁴⁵ The restricted formation notes for clarification that the necessity of ensuring the confidentiality of channels for transmitting personal data has been emphasized by ANSSI since 2013, particularly in its "Recommendations for the implementation of a website: mastering browser-side security standards," which specify that "the implementation of HTTPS on a website or web application is a security guarantee based on TLS to ensure the confidentiality and integrity of exchanged information, as well as the authenticity of the contacted server. The absence of this guarantee can lead to numerous abuses even if the intention is not malicious."¹⁴⁶ The restricted formation also notes that the Commission has consistently recommended since the publication of its guide "The security of personal data" in 2018 to implement, as basic precautions, the "TLS" protocol using only the most recent versions and verifying its proper implementation.¹⁴⁷ The restricted formation further notes that the personal data in question are highly sensitive since they are banking data. Therefore, taking into account these risks for the protection of personal data and the privacy of individuals leads the restricted formation to consider that the measures deployed to ensure the security of the data, in this case, are insufficient as these data transit during their transmission between the user's browser and the server hosting the site.¹⁴⁸ Consequently, the restricted panel considers, with regard to the personal data subject to processing (notably, banking data), that the absence of the implementation of the basic security measure that constitutes the use of the "HTTPS" protocol or another equivalent security measure characterizes a breach of Article 32 of the GDPR. The restricted panel notes, however, the modification of the protocol by the company during the proceedings. It reminds, however, that the compliance measures taken cannot exempt the company from its liability for the identified breach.

I. On the breach related to the obligation to notify personal data breaches to the CNIL in accordance with Article 33 of the GDPR¹⁴⁹. Article 4, 12) of the GDPR defines a personal data breach as "a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of personal data transmitted, stored, or otherwise processed, or unauthorized access to such data."¹⁵⁰ Article 33 of the GDPR states that "in the event of a personal data breach, the data controller shall notify the breach to the competent supervisory authority in accordance with Article 55, without undue delay and, where feasible, not later than 72 hours after becoming aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When notification to the supervisory authority is not carried out within 72 hours, it shall be accompanied by the reasons for the delay (...) If, and to the extent that, it is not possible to provide all the information at the same time, the information may be provided in phases without any further undue delay."¹⁵¹ Recital 87 of the GDPR specifies that "it is important to ascertain whether all appropriate technical and

organizational protection measures have been implemented to establish immediately whether a personal data breach has occurred and to inform the supervisory authority and the data subject quickly."¹⁵² The rapporteur notes that the company became aware of the personal data breach on September 29, 2020, when a journalist communicated a sample of the impacted data to it, or at the latest on September 30, 2020, following its internal investigation.¹⁵³ According to her, the data breach was likely to pose a risk to the rights and freedoms of the data subjects, particularly considering the duration of the breach (two months and four days) and the potential number of affected individuals ([...] clients and prospects in the database).¹⁵⁴ Therefore, she considers that the existence of the personal data breach should have been notified to the CNIL by the company, if necessary in a phased manner.¹⁵⁵ In defense, the company acknowledges having learned of the existence of the security incident on September 29, 2020. However, it indicates that access to the server in question had been closed since July 10, 2020, which ended the security incident.¹⁵⁶ It attributes the responsibility for this security incident to its subcontractor, responsible for IT management. Indeed, it states that after requesting its subcontractor to grant access to its server to its developer, the subcontractor acted outside of its instructions by making the server accessible to unauthorized third parties.¹⁵⁷ Finally, the company disputes the volume indicated by the rapporteur concerning the clients and prospects registered in its database. It considers that it contains the email addresses of [...] clients and [...] prospects.¹⁵⁸ The restricted panel reminds that, in accordance with Article 33 of the GDPR, in informed the CNIL because it believed that the incident did not pose a risk to the rights and freedoms of individuals.¹⁶⁸ The restricted formation emphasizes that the absence of notification to the supervisory authority is only permissible in exceptional cases, and the burden of proof lies with the data controller to demonstrate that the violation does not entail such a risk.¹⁶⁹ Furthermore, the restricted formation reiterates that the data controller must assess the potential impact of the data breach on the affected individuals and take into account the nature of the personal data involved, the context of the breach, and the likelihood of harm arising from it.¹⁷⁰ In this context, the restricted formation highlights that the data controller's assessment must be documented and that the decision not to notify the supervisory authority should be justified with clear reasoning.¹⁷¹ The restricted formation concludes that the failure to notify the CNIL constitutes a breach of the obligations set forth in the GDPR, which could lead to administrative sanctions.¹⁷² It is essential for data controllers to establish and maintain effective procedures for detecting, reporting, and investigating personal data breaches to ensure compliance with the GDPR and protect the rights of individuals.¹⁷³ The restricted formation recommends that organizations implement training and awareness programs for their staff to ensure that they understand their responsibilities regarding data protection and breach notification.¹⁷⁴ Finally, the restricted formation stresses the importance of a proactive approach to data security, including regular audits and assessments of data processing activities, to mitigate the risk of future breaches.

data breach since the journalist's alert occurred after the server was shut down and that its subcontractor, responsible for IT management, did not retain the connection logs for the concerned server. ¹⁶⁸ According to the restricted panel, the company did not implement all appropriate measures to immediately establish the existence of the personal data breach. ¹⁶⁹ Indeed, the restricted panel believes that even though the company was alerted to the security incident after the server was shut down, it was able to identify the existence of a data breach by comparing the sample of data provided by the journalist with its own database. ¹⁷⁰ Furthermore, the restricted panel notes the lateness of the request for the connection logs from the subcontractor, as this only occurred on November 25, 2020, two months after the journalist's alert. ¹⁷¹ Given the elements mentioned above, the restricted panel considers that, at the latest by September 30, 2020, the date of the internal investigation, the company had a reasonable degree of certainty regarding the existence of a data breach posing a risk to the rights and freedoms of the affected individuals, particularly considering the duration of the breach (two months and four days) and the potential number of affected individuals, namely [...] clients and prospects. ¹⁷² The restricted panel notes that the company, as the data controller, had the obligation to notify the occurrence of a data breach even if the breach was due to an error attributable to the subcontractor. ¹⁷³ Therefore, the restricted panel considers that the company failed in its obligations by not notifying the CNIL of the data breach. ¹⁷⁴ It follows from the above that

the restricted panel considers that a breach of Article 33 of the GDPR is established. J. On the breach relating to Article 82 of the Data Protection Act 175. Article 82 of the Data Protection Act states that "any subscriber or user of an electronic communications service must be informed clearly and completely, unless they have been informed beforehand, by the data controller or their representative: 1° Of the purpose of any action aimed at accessing, by means of electronic transmission, information already stored in their terminal equipment for electronic communications, or at entering information into this equipment; 2° Of the means available to oppose this [...]". These accesses or entries may only occur provided that the subscriber or user has expressed, after receiving this information, their consent, which may result from appropriate settings of their connection device or any other device under their control (...) However, these provisions do not apply if access to information stored in the user's terminal equipment or the entry of information into the user's terminal equipment: 1° Is exclusively for the purpose of enabling or facilitating electronic communication; 2° Is strictly necessary for the provision of an online communication service at the express request of the user." 176. These provisions transpose into French law Article 5, paragraph 3, of Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector (the "e-Privacy Directive"). 177. Firstly, the rapporteur notes that the delegation found, during the online inspection on April 15, 2021, the absence of a banner or interface for information and consent regarding cookies when accessing the website www.voyance-en-direct.tv, while certain cookies were being placed on users' terminals. 178. It notes that, during the on-site inspection on July 15, 2021, the delegation observed the presence of a cookie banner when accessing this website. 179. However, it considers that the information provided is not satisfactory and does not clarify the consent of the data subject, as no information is provided regarding how to refuse trackers, the consequences of a refusal, and the existence of the right to withdraw consent. 180. In defense, the company argues that, since the notification of the report, it has implemented a compliant cookie banner on its website. 181. The restricted formation recalls that it follows from the combined provisions of Article 82 of the Data Protection Act and Article 4 of the GDPR that trackers requiring consent cannot, subject to the exceptions provided for by these provisions, be used for writing or reading unless the user has freely, specifically, unambiguously, and informedly expressed their consent through a positive action. 182. The restricted formation considers that the validity of consent is therefore particularly linked to the quality of the information received. 183. For clarification, the restricted formation indicates that in the guidelines related to the application of Article 82 of the Data Protection Act to reading and writing operations on a user's terminal, the Commission specifies, regarding the informed nature of consent, that "at a minimum, the provision of the following information to users, prior to obtaining their consent, is necessary to ensure the informed nature of that consent: - the identity of the data controller(s) for the reading or writing operations; - the purpose of the reading or writing operations of the data; - how to accept or refuse trackers; - the consequences of refusing or accepting trackers; - the existence of the right to withdraw consent." 184. The Commission specifies, in its recommendation proposing practical compliance measures in the case of the use of cookies and other trackers dated September 17, 2020, that "in practice, in order to reconcile the requirements of clarity and conciseness of information with the need to identify all data controllers, specific information about these entities (identity, link to their personal data processing policy), regularly updated, can for example be provided at a second level of information. They can thus be made available from the first level via, for example, a hyperlink or a button accessible from this level." Therefore, information regarding the identity of the data controller(s) for the reading or writing operations can be provided at a second level of information. 185. The restricted formation also notes that the Commission indicates, by way of illustration, in the questions and answers on the amending guidelines and the recommendation "cookies and other trackers" from the CNIL dated November 4, 2022, that "in order for the user's consent to be informed, all the information recalled in Article 2 of the guidelines 'cookies and other trackers' must be available at the time of collecting their choice. It is recommended, at the first level of information, to clearly indicate the purposes of the cookies, to allow the user to access the list of data controllers via, for example, a hyperlink or a button accessible from the first level of information, to inform them of the possibility to withdraw consent at any time and, when relevant, the consequences resulting from a refusal of

cookies."¹⁸⁶. The restricted formation notes that on the day of the online inspection, the website www.voyance-en-direct.tv did not have an information banner regarding the cookies placed on users' terminals when accessing the website. Users were therefore neither informed of the operations carried out nor able to consent in advance, as required by Article 82 of the Data Protection Act as clarified by Article 4 of the GDPR.¹⁸⁷. The restricted formation notes that it was only during the on-site inspection on July 15, 2021, that the delegation observed, upon accessing this website, the presence of the following cookie banner: "We use cookies and other tracking technologies to enhance your browsing experience on our site, to show you personalized content and targeted advertisements, to analyze our site traffic, and to understand the origin of our visitors," containing the buttons "I accept" and "Change my preferences."¹⁸⁸. It also notes that after clicking on the "Change my preferences" button, the user accesses the following information: "You can modify your preferences and refuse the recording of certain types of cookies on your computer while browsing our site. You can also delete cookies already stored on your computer, but keep in mind that their deletion may prevent you from using certain elements of our website."¹⁸⁹. The restricted formation notes that, during the on-site inspection on July 15, 2021, the first level of information provided to users did not allow them to be informed of the possibility and the manner of refusing trackers, as well as the consequences of a refusal, nor of the right to withdraw consent.¹⁹⁰. The restricted formation notes that on the day of the restricted formation session, when accessing the website www.voyance-en-direct.tv, the cookie banner present on the website contained the following mention and the buttons "I accept," "I refuse," and "Change my preferences."

****Preferences**:** "We use cookies and other tracking technologies to enhance your browsing experience on our site, to show you personalized content and targeted advertisements, to analyze traffic on our site, and to understand the origin of our visitors."

Consequently, the restricted panel considers that the aforementioned facts constitute a breach of Article 82 of the Data Protection Act, as at the time of the online inspection and until the modification of the cookie banner, when accessing the website www.voyance-en-direct.tv, users were not informed of the existence of operations allowing access to or registration of information on their terminal, in accordance with Article 82 of the Data Protection Act and Article 4 of the GDPR, and therefore were not able to consent in an informed manner.

Secondly, the reporter notes that the delegation found, during the online inspection on April 15, 2021, that three cookies, subject to the prior collection of user consent, were placed on users' terminals as soon as they accessed the website www.voyance-en-direct.tv, before any action on their part, without their consent being collected beforehand.

In defense, the company argues that, since the notification of the report, no non-essential cookie for the functioning of the site has been placed on the user's terminal.

The restricted panel recalls that Article 82 of the Data Protection Act requires consent for operations of reading and writing information on a user's terminal but provides specific cases in which certain trackers are exempt from consent: either when the sole purpose is to enable or facilitate electronic communication, or when it is strictly necessary for the provision of an online communication service at the express request of the user.

Regarding audience measurement trackers exempt from consent collection, the restricted panel notes, by way of illustration, that the Commission specifies in its guidelines of September 17, 2020, that "these measurements are in many cases essential for the proper functioning of the site or application and therefore for the provision of the service. Consequently, the Commission considers that trackers whose purpose is limited to measuring the audience of the site or application, to meet various needs (performance measurement, detection of navigation problems, optimization of technical performance or ergonomics, estimation of the power of necessary servers, analysis of consulted content, etc.) are strictly necessary for the functioning and routine administrative operations of a website (...) In order to limit itself to what is strictly necessary for the provision of the service, the Commission emphasizes that these trackers must have a purpose strictly limited to the sole measurement of the audience on the site or application for the exclusive account of the publisher."

Regarding multi-purpose trackers, the restricted panel notes, again by way of illustration, that the Commission specifies in its guidelines of September 17, 2020, that "the use of the same tracker for multiple purposes, some of which do not fall within the scope of these exemptions, requires prior consent from the individuals concerned, under the conditions recalled by these guidelines. For example, in the case of a service offered via a platform requiring user authentication ("logged-in universe"), the service publisher may use a cookie to authenticate users without asking for their consent (as this cookie is strictly necessary for the provision of the online communication service). However, it cannot use this same cookie for purposes...

advertising purposes only if the latter have indeed consented beforehand to this specific purpose.

197. The restricted formation considers that in order to determine whether the placement of a multi-purpose cookie on users' terminals requires prior consent, it is necessary to ascertain whether at least one of the purposes requires prior consent.

198. In this case, the restricted formation notes that the company deposits and reads the following cookies on users' terminals as soon as they access the website www.voyance-en-direct.tv, before any action on their part, without obtaining prior consent: the cookies "test_cookie", ".ga", and ".gid".

199. Regarding the cookie "test_cookie", the restricted formation notes that it serves an advertising purpose. Therefore, it does not fall under any of the exceptions defined in Article 82 of the Data Protection Act and cannot be placed on the user's terminal without prior consent.

200. Concerning the cookies ".ga" and ".gid", the restricted formation notes that they serve multiple purposes, namely a purpose related to the tracking and analysis of the website www.voyance-en-direct.tv and a purpose specific to Google concerning the maintenance and protection of the Analytics service. Consequently, these cookies do not have the exclusive purpose of enabling or facilitating electronic communication and are not strictly necessary for the provision of the service. Therefore, they do not fall under any of the exceptions defined in Article 82 of the Data Protection Act and cannot be placed on the user's terminal without prior consent.

201. The restricted formation thus considers that the placement and reading of these cookies on the user's terminal require the user to give prior consent, under the conditions provided by Article 82 of the Data Protection Act, as clarified by Article 4, paragraph 11, of the GDPR.

202. The restricted formation recalls that it has, on several occasions, imposed financial penalties for violations of Article 82 of the Data Protection Act concerning the placement of cookies for which prior consent is mandatory, on users' terminals, before any action on their part, without obtaining prior consent (notably decisions SAN-2022-023 of December 19, 2022, SAN-2022-025, SAN-2022-026, and SAN-2022-027 of December 29, 2022).

203. Consequently, the restricted formation considers that the aforementioned facts constitute a violation of Article 82 of the Data Protection Act for the facts noted on the day of the inspections, as cookies subject to the requirement for prior consent were placed on users' terminals before any action on their part, without their consent.

204. The restricted formation notes that during the procedure, the company KG COM indicated that it had complied with the requirements of Article 82 of the Data Protection Act since it no longer places any cookies that are not essential for the operation of the website www.voyance-en-direct.tv.

205. Thirdly, the rapporteur notes that during the on-site inspection on July 15, 2021, the inspection delegation found that the cookie banner present on the website www.voyance-en-direct.tv did not allow users to refuse cookies as easily as to accept them.

206. In its defense, the company argues that its cookie banner will soon include a "refuse" button.

207. The restricted formation believes that to ensure the freedom of consent, it should be as easy to refuse cookies as it is to accept them.

208. For clarification, the restricted formation indicates that in the guidelines regarding the application of Article 82 of the Data Protection Act to...

****Reading and Writing Operations in the Terminal of a User****

The Commission specifies that "the expression of the user's refusal must therefore not require any action on their part or must be able to be expressed through an action that presents the same degree of simplicity as that allowing them to express their consent." 209. The restricted formation notes that,

as evidenced by the findings made during the on-site inspection on July 15, 2021, when a user visited the website www.voyance-en-direct.tv, they could accept the deposit of cookies, subject to prior consent, in a single action by clicking on the button titled "I accept" displayed on the cookie banner. 210. It notes that, on the other hand, to refuse these cookies, the user had to perform no less than five actions: click on the button "Change my preferences" to access the cookie management interface (first click), click on the tabs "Functional Cookies" (second click), "Tracking and Performance Cookies" (third click), "Targeting and Advertising Cookies" (fourth click) to make a choice regarding the deposit of these cookies, and click on the button "Save my preferences" (fifth click). 211. The restricted formation considers that it was therefore not as simple to refuse cookies as it was to accept them and that making the mechanism for refusing cookies more complex than that for accepting them effectively discourages users from refusing cookies and encourages them to favor the ease of the "Accept All" button. Indeed, an Internet user is generally led to consult many sites. Internet browsing is characterized by its speed and fluidity. The need to click on "Change my preferences" and to understand how the page for refusing cookies is structured is likely to discourage the user, who would nonetheless wish to refuse the deposit of cookies. It is undisputed that in this case, the company offered a choice between accepting or refusing cookies before the insertion of the "Reject All" button, but the means by which this refusal could be expressed, in the context of Internet browsing, skewed the expression of choice in favor of consent in a way that altered the freedom of choice. 212. The restricted formation emphasizes that it has, on several occasions, imposed financial penalties for violations of Article 82 of the Data Protection Act in cases where it was not as simple for users to refuse cookies as it was to accept them. It notably held in deliberations SAN-2022-023 of December 19, 2022, and SAN-2022-027 of December 29, 2022, that "making the mechanism for refusing cookies more complex than that for accepting them effectively discourages users from refusing cookies and encourages them to favor the ease of the 'Accept' button. Indeed, an Internet user is generally led to consult many sites. Internet browsing is characterized by its speed and fluidity. The need to click on 'More options' and to understand how the page for refusing cookies is structured is likely to discourage the user, who would nonetheless wish to refuse the deposit of cookies. It is undisputed that in this case, the company offered a choice between accepting or refusing cookies before the insertion of the 'Reject All' button, but the means by which this refusal could be expressed, in the context of Internet browsing, skewed the expression of choice in favor of consent in a way that altered the freedom of choice" (also in deliberations SAN-2021-023 and SAN-2021-024 of December 31, 2021). 213. The restricted formation notes that on the day of the restricted formation session, when accessing the website...

www.voyance-en-direct.tv, the cookie banner present on the website included a "I refuse" button. 214. Therefore, the restricted formation considers that a breach of the provisions of Article 82 of the Data Protection Act, interpreted in light of the GDPR, is constituted, insofar as, at the time of the online check and until the implementation of the "Reject All" button, the user did not have the option to refuse reading and/or writing operations with the same degree of simplicity as they had to accept them.

III. On the sanction and publicity²¹⁵. According to III of Article 20 of the Data Protection Act: "When the data controller or its processor fails to comply with the obligations arising from Regulation (EU) 2016/679 of April 27, 2016, or from this law, the president of the National Commission for Information Technology and Civil Liberties may also, if necessary after having sent them the warning provided for in I of this article or, if necessary, in addition to a formal notice provided for in II, refer the restricted formation of the commission for the purpose of pronouncing, after adversarial proceedings, one or more of the following measures: [...] 7° Except in cases where the processing is carried out by the State, an administrative fine not exceeding 10 million euros or, in the case of a company, 2% of the total global annual turnover of the previous financial year, the higher amount being retained. In the cases mentioned in 5 and 6 of Article 83 of Regulation (EU) 2016/679 of April 27, 2016, these ceilings are raised, respectively, to 20 million euros and 4% of said turnover. The restricted formation takes into account, in determining the amount of the fine, the criteria specified in the same Article 83."

216. Article 83 of the GDPR provides that "Each supervisory authority ensures that the administrative fines imposed pursuant to this article for violations of this regulation referred to in paragraphs 4, 5, and

6 are, in each case, effective, proportionate, and dissuasive," before specifying the elements to be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine.

217. Firstly, regarding the principle of imposing a fine, the company emphasizes in its defense the responsibility of its subcontractor concerning the breaches related to security and the origin of the security incident. It indicates that the data that may have been accessible does not concern highly personal or sensitive data. Furthermore, it contests the number of affected individuals, without providing a volume.

218. It also recalls the absence of complaints and considers that certain breaches are of little harm to the individuals concerned, particularly the breaches of Articles 12 and 28 of the GDPR. It also highlights the efforts it has made to comply following the notification of the report.

219. The restricted formation recalls, first, that it must take into account, for the imposition of an administrative fine, the criteria specified in Article 83 of the GDPR, such as the nature, gravity, and duration of the violation, the measures taken by the data controller to mitigate the damage suffered by the individuals concerned, the degree of cooperation with the supervisory authority, and the categories of personal data concerned by the violation.

220. The restricted formation also notes the particularly high number of breaches: nine breaches under the GDPR (Articles 5-1-c, 5-1-e, 6, 9, 12 and 13, 28, 32, 33) and one breach under the Data Protection Act (Article 82). The company has thus demonstrated multiple failures since the breaches constituted concern a large part of the rules relating to the protection of personal data, of which

****of the fundamental obligations of the data controller (data minimization, limitation of data retention and accessibility of information, lawfulness of processing).****

221. For example, the complete and systematic recording of all telephone calls made between teleoperators and prospects, as well as between agents and clients, for the purposes of quality control and evidence, constitutes a particularly intrusive practice for the individuals concerned.

222. Furthermore, the company did not comply with Article 82 of the Data Protection Act on several aspects: lack of information, absence of consent for the placement of non-exempt cookies, and imbalance between the options offered to the user to accept or refuse the placement of cookies on their device. These facts constitute a substantial infringement of the right to respect for private life and the protection of personal data of the individuals concerned.

223. The restricted formation also recalls, by way of illustration, that the company did not notify the CNIL of the data breach while it had all the elements necessary to verify its existence and identified as a probable consequence of this breach, unsolicited commercial prospecting.

224. The restricted formation notes that some violations concern specific categories of data subject to strict legal regimes (health data, information on sexual orientation) and highly personal data (banking data) that require heightened vigilance given the risk of fraud.

225. The restricted formation also recalls that as the data controller, the company is required to comply with its obligations under the GDPR. It is particularly required to exercise satisfactory and regular control over the technical and organizational measures implemented by its subcontractor to ensure compliance with the GDPR and, in particular, to ensure the security of personal data processed.

226. In this regard, the restricted formation notes that several basic security measures were lacking in this case, resulting in a risk for the individuals concerned. The restricted formation recalls that the various documents governing the contractual relationships between the company and its subcontractors do not include all the measures required by Article 28 of the GDPR, and some documents are not signed by the service providers. These facts do not ensure effective protection of personal data processed through contractual guarantees.

227. Finally, the restricted formation notes that the compliance measures implemented by the company following the notification of the report, particularly regarding cookies, do not exempt the organization from its liability for the violations identified in the past.

228. Consequently, the restricted formation considers that an administrative fine should be imposed for violations of Articles 5-1-c) and e), 6, 9, 12, 13, 28, 32, and 33 of the GDPR and Article 82 of the Data

Protection Act.

229. Secondly, regarding the amount of the fine, the organization insists in its defense on the deficit nature of its net result.

230. The restricted formation considers that the financial situation of the organization must be taken into account in determining the sanction and, in the case of an administrative fine, its amount. It notes in this regard that in 2020, the net revenue of the company KG COM amounted to [...] euros and its net loss was [...] euros. The company indicated, for reference, during the restricted formation session that its projected revenue from January to August 2022 is approximately [...] euros, or about [...] euros for the year 2022.

231. Therefore, in light of the relevant criteria of Article 83, paragraph 2, of the GDPR mentioned above, the restricted formation considers the imposition of an administrative fine of 150,000 euros justified, distributed as follows: 120,000 euros for violations of the GDPR and 30,000 euros for the violation of the Data Protection Act.

232. Thirdly, regarding the publicity of the sanction, the organization argues that such a measure would be economically detrimental to it.

233. The restricted formation considers that, in view of the plurality of violations identified, their severity, the particular nature of the data processed, and the number of individuals concerned, the publicity of this decision is justified.

****FOR THESE REASONS****

The restricted formation of the CNIL, after deliberation, decides to:

- impose an administrative fine of 120,000 (one hundred twenty thousand) euros on the company KG COM for violations of Articles 5-1-c) and e), 6, 9, 12, 13, 28, 32, and 33 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of personal data and the free movement of such data, and an amount of 30,000 (thirty thousand) euros for the violation of Article 82 of the Data Protection Act;
- make public, on the CNIL website and on the Légifrance website, its deliberation, which will no longer specifically identify the company KG COM after a period of two years from its publication.

The President, Alexandre LINDEN

This decision may be subject to appeal before the Council of State within two months from its notification.